Agentpathogene@parrot~$ rpcclient -U "" -N ip
rpcclient $> querydominfo
Ou pour la politique de mot de pass :
rpcclient $> getdompwinfo

Nous avons aussi le fameux enum4linux (Ex: avec -P Pour password policies)

Agentpathogene@parrot~$ enum4linux -P ipcible

- Notons que nous avons aussi la réécriture d'enum4linux en python nommé enum4linux-ng qui possède la capacité d'exporter les données ~~en~~ récoltés en fichiers YAML ou JSON - (Et produire une sortie colorée ;)).

Agentpathogene@parrot~$ enum4linux-ng. -P ipcible -oT fichierexport.txt

- Pour "exfiltration" complète, utilisateurs, groupes, partages SMB etc on peux utiliser l'option -A - (N'oublions pas de lire l'aide de l'outil avant de le lancer

Enumeration Null Session Depuis Windows :

Nous courant de réaliser ce type d'attaque depuis Windows (En vrai justement tant qu'on peux casser les TTP...) - Bon voyons juste comment établir une session null depuis windows

C:\target> net use \\DC01\ipc$ "" /u:""

Enumerer Politique MDP Depuis Linux - Liaison Anonyme LDAP :

Une liaison anonyme LDAP désigne une méthode de connexion à un serveur d'annuaire LDAP (Comme AD ou OpenLDAP) dans laquelle le client ne fournit aucune information d'identification

Elle nous permet entre autre de récupérer la politique de mot de pass du domaine. Pour ce faire on peux utiliser de nombreux outils notemment ldapsearch Dans la command ci-dessous on spécifie une auth simple (-x) sans nom d'utilisateurs (-D) ni mdp (-W) - On définit la base de la recherche à la racine du domaine, le scope (ici sub donc base de départ + intégralité des sous dossiers) on retourne tout les attributs standart des objets trouvés "*" On pipe la reponse a grep qui s'arrête à la première occurence de l'attribut pwdHistoryLength ? c'est l'attribut qui stockent le nb de mdp qu'un user doit configurer avant de pouvoir réutiliser un ancien (oui ca a l'air con)) et on before de 10 ligne c'est là sur ces lignes que se trouve la politique du mdp

Agentpathogene@parrot~$ ldapsearch -H ip -b "DC=DOMAIN,DC=LOCAL" -s sub "*" | grep -m 1 -B 10 pwdHistoryLength

Enumeration Politique de MDP - Depuis Windows :

Si on peux s'authentifier sur le domaine le mieux est d'enumerer les binnaries windows intégrés comme net.exe pour récupérer la politique de mot de pass mais on peux également utiliser des outils comme PowerView

① C:\Windows> net accounts

② C:\Windows> import-module PowerView.ps1
C:\Windows> Get-DomainPolicy

Voila quelques manière d'extraire la politique de MDP en vue de password spraying rappelons la prudence extrême nécessaire pour ne rien bloquer ...